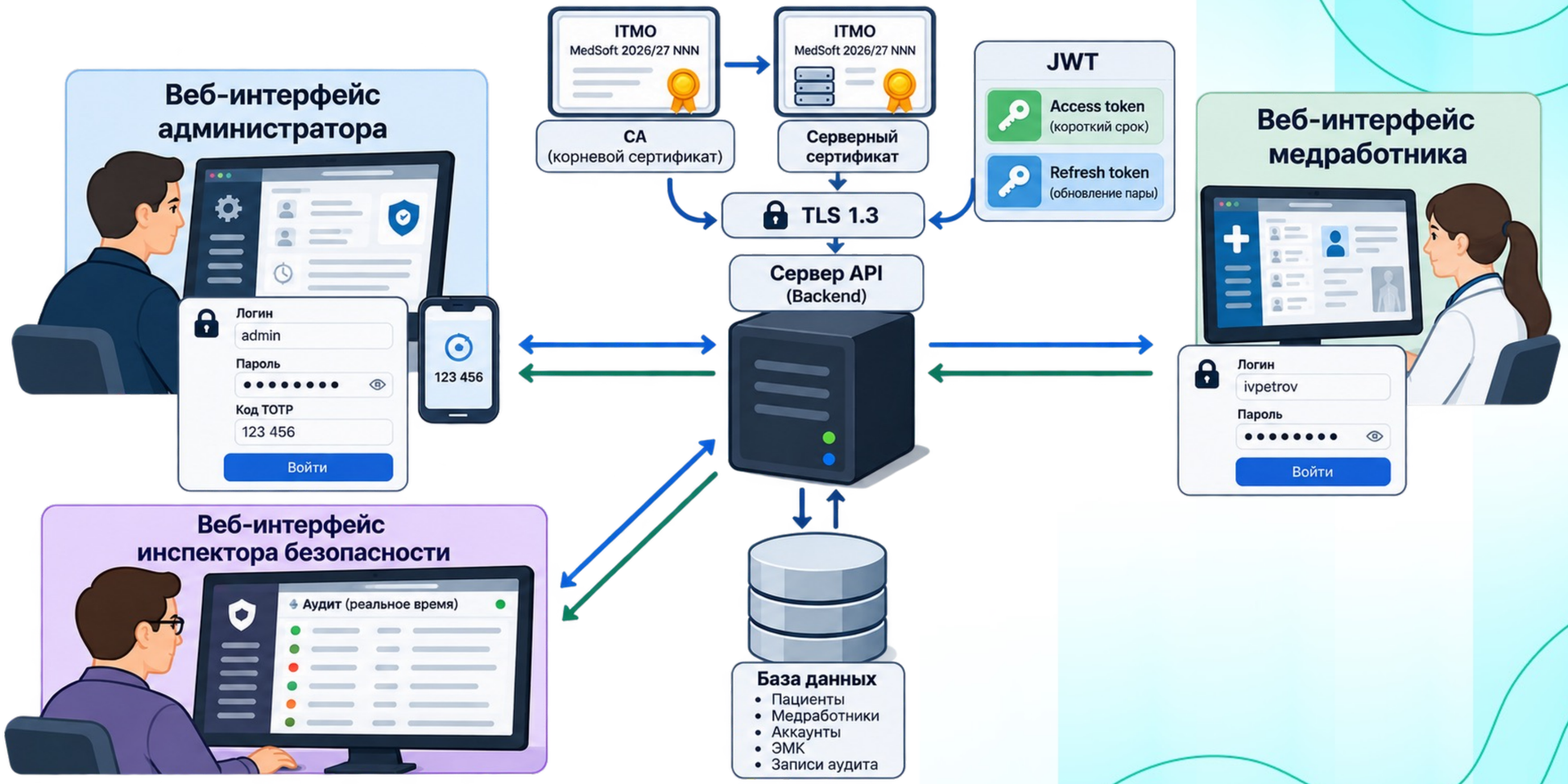
ИТМО x MVS

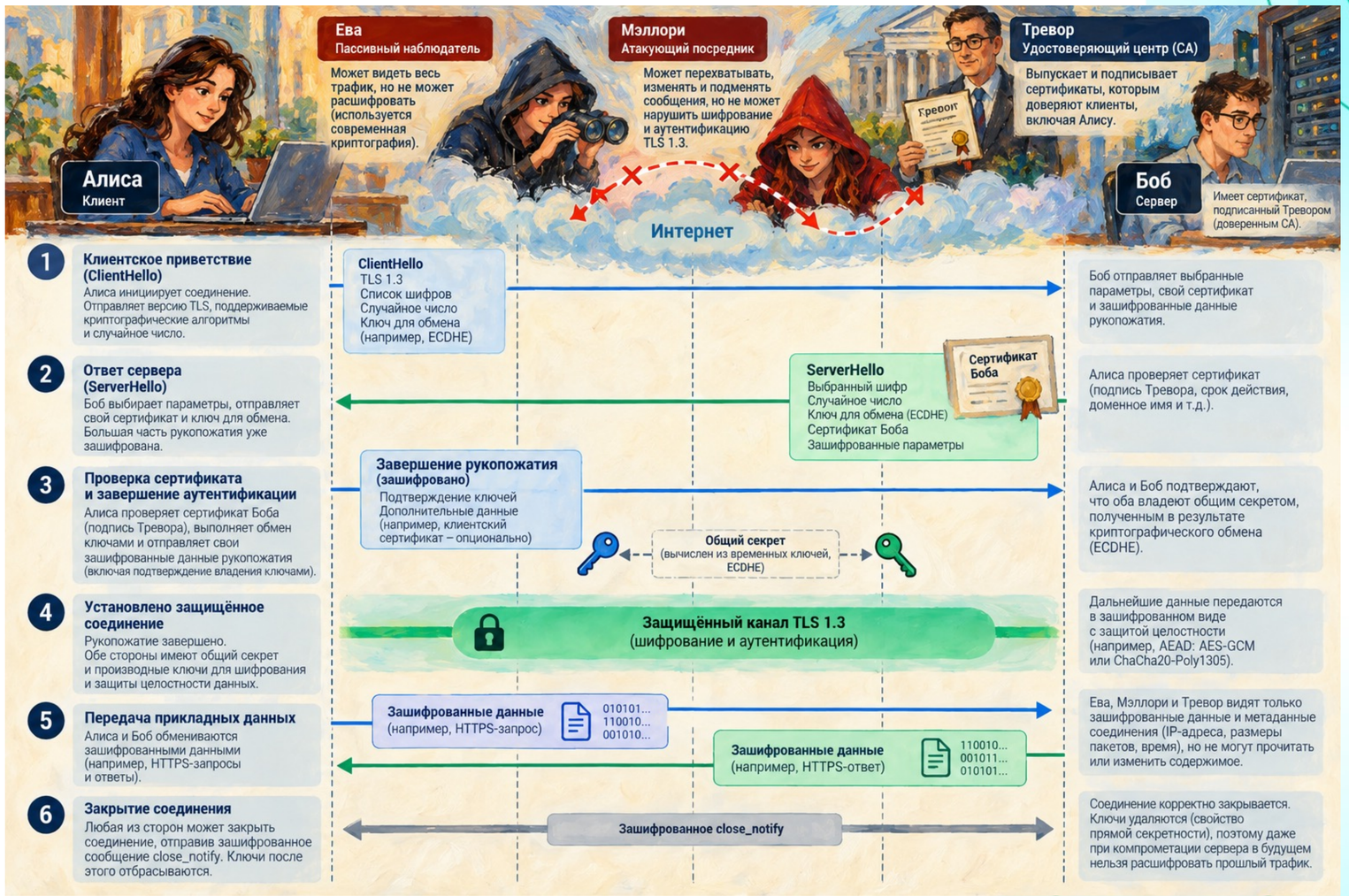
Безопасность: Криптопротоколы

Лекция шестая

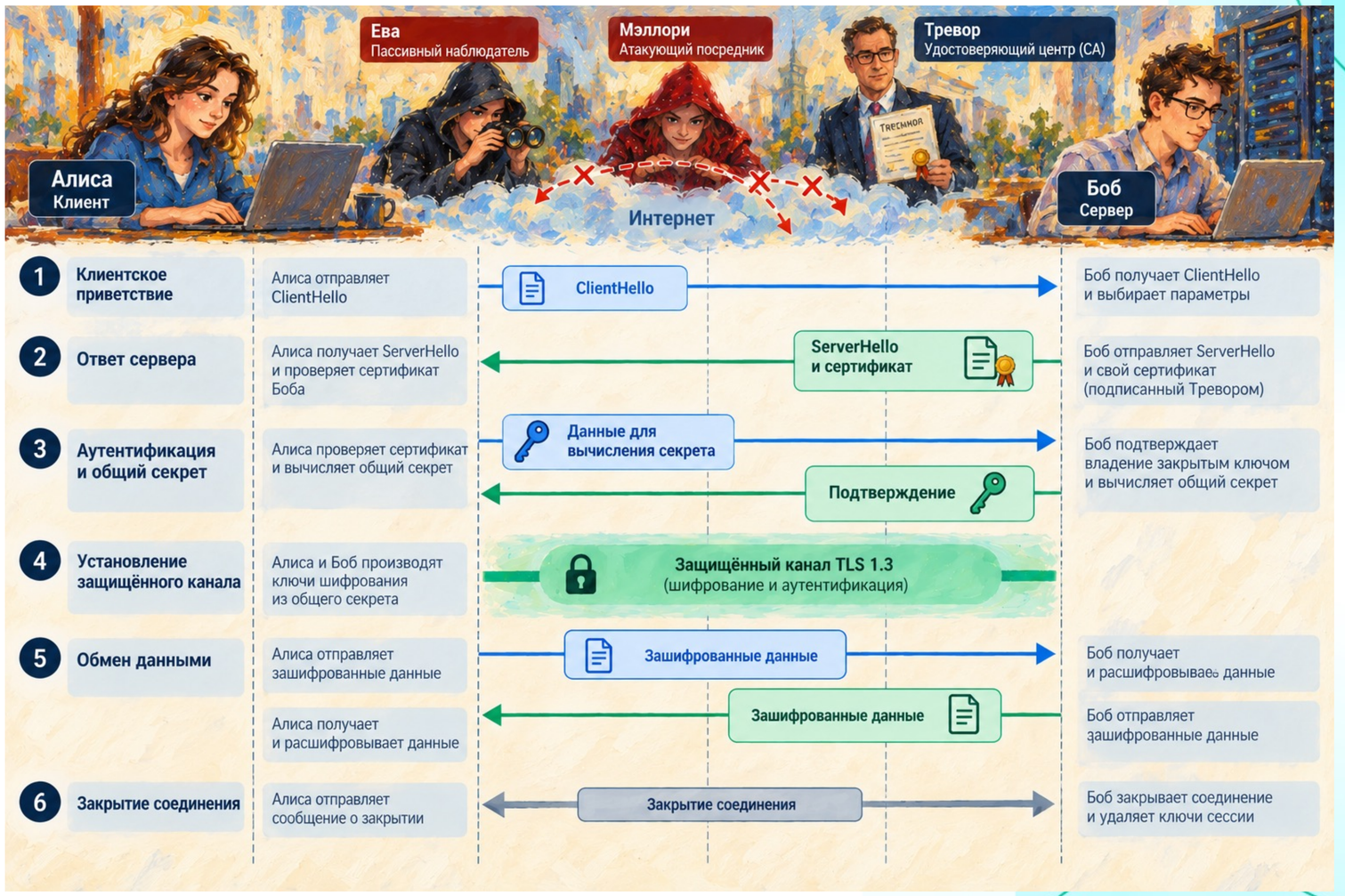
Лабораторная 2: Базовая защита



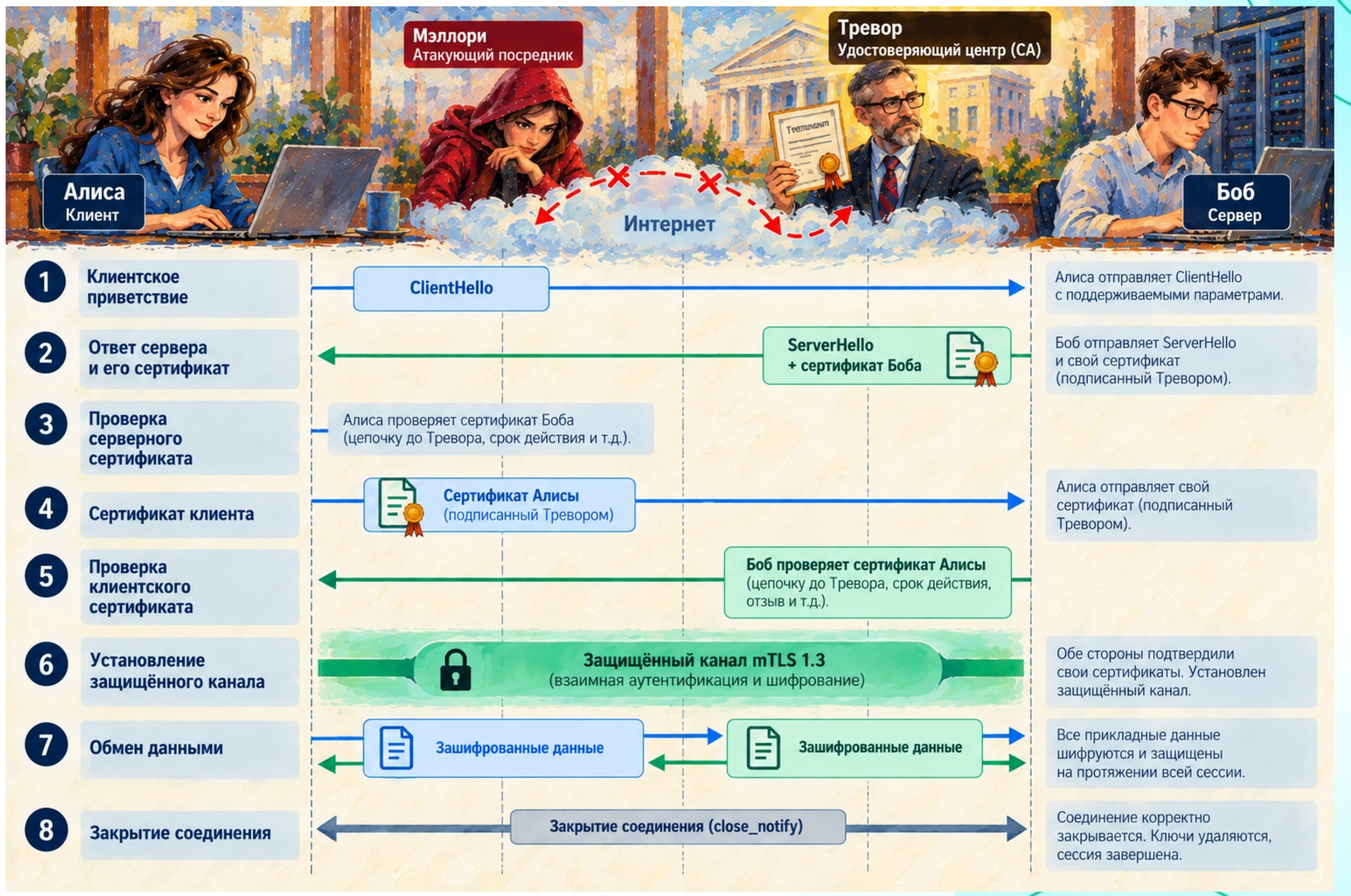
Защищаем трафик: TLS



Защищаем трафик: TLS



Защищаем трафик: mTLS



ИТМО x MVS

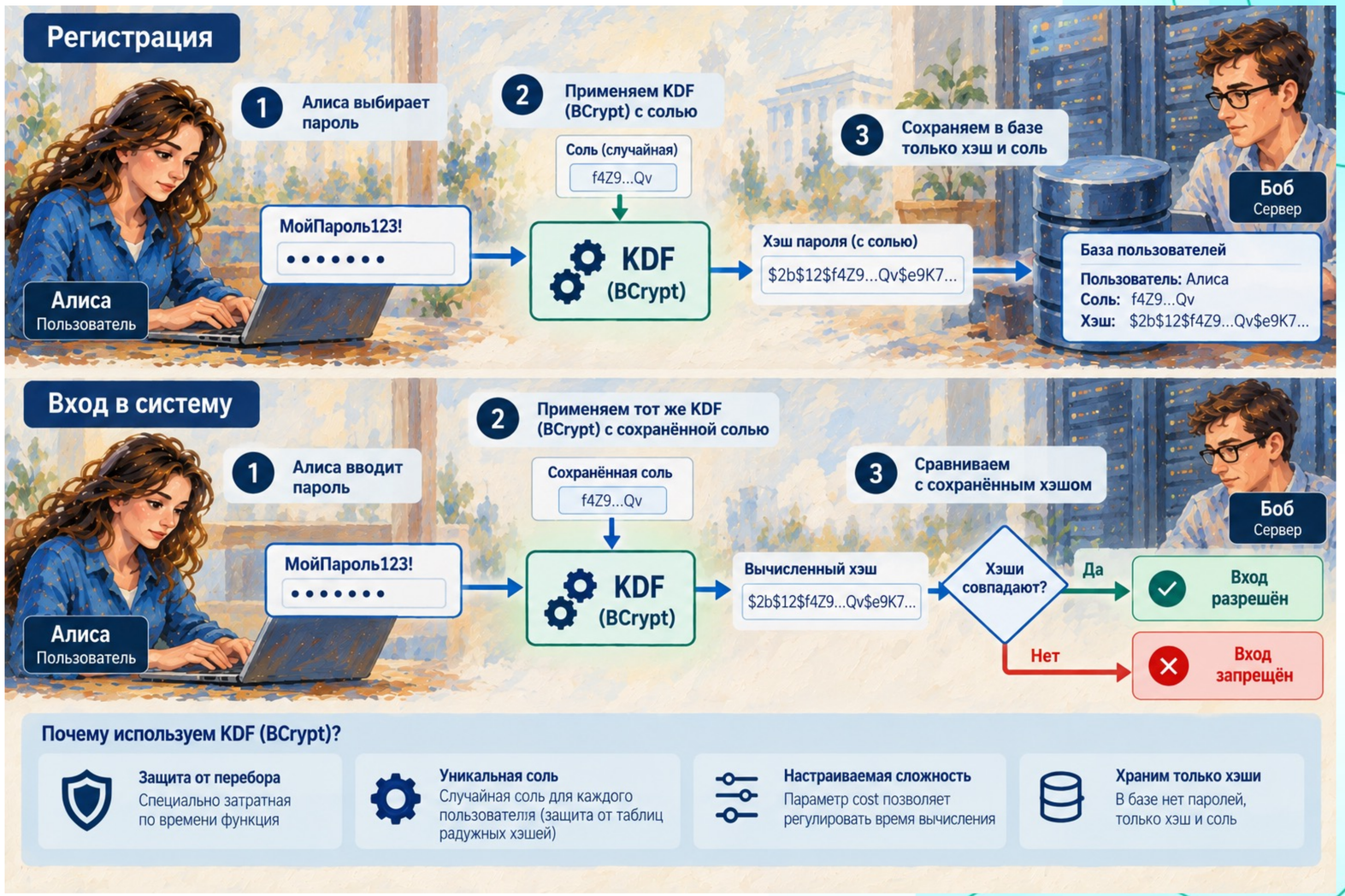
Защищаем трафик: Самоподписанный сертификат

- Выпускаете свой корневой сертификат
- Добавляете его в доверенные
- Подписываете серверные и клиентские сертификаты своим корневым сертификатом
- Let‘s Encrypt
- OpenSSL, XCA (https://hohnstaedt.de/xca/index.php)

AAA: Authentication, Authorization, Accounting



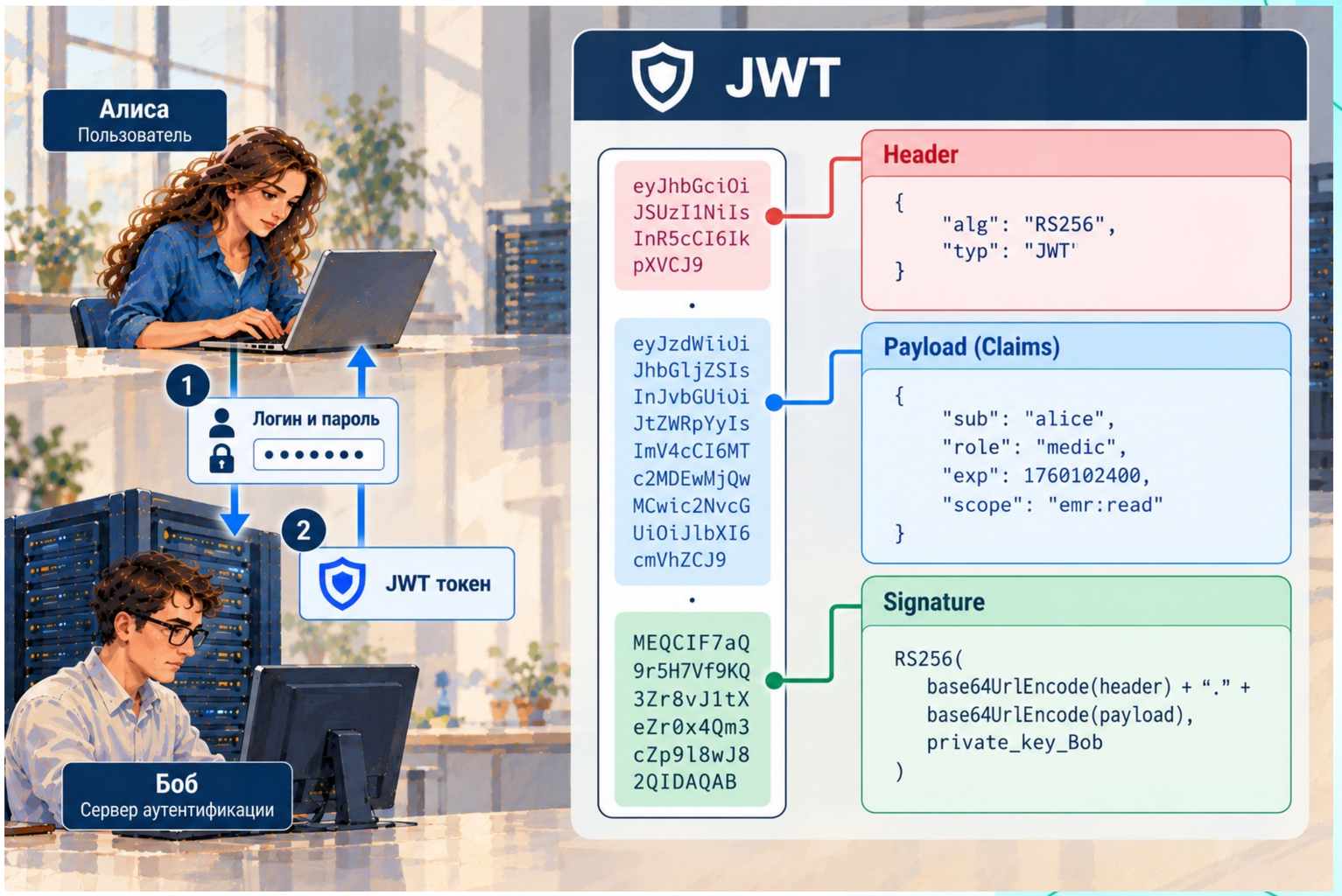
Пароли


Регистрация
1 Алиса выбирает пароль
2 Применяем KDF (BCrypt) с солью
Соль (случайная)
f4Z9...Qv
3 Сохраняем в базе только хэш и соль
МойПароль123!
••••••••
KDF (BCrypt)
Хэш пароля (с солью)
$2b$12$f4Z9...Qv$e9K7...
Боб
Сервер
База пользователей
Пользователь: Алиса
Соль: f4Z9...Qv
Хэш: $2b$12$f4Z9...Qv$e9K7...
Алиса
Пользователь
Вход в систему
1 Алиса вводит пароль
2 Применяем тот же KDF (BCrypt) с сохранённой солью
Сохранённая соль
f4Z9...Qv
3 Сравниваем с сохранённым хэшом
МойПароль123!
••••••••
KDF (BCrypt)
Вычисленный хэш
$2b$12$f4Z9...Qv$e9K7...
Хэши совпадают?
Да
Вход разрешён
Нет
Вход запрещён
Почему используем KDF (BCrypt)?
Защита от перебора
Специально затратная по времени функция
Уникальная соль
Случайная соль для каждого пользователя (защита от таблиц радужных хэшей)
Настраиваемая сложность
Параметр cost позволяет регулировать время вычисления
Храним только хэши
В базе нет паролей, только хэш и соль

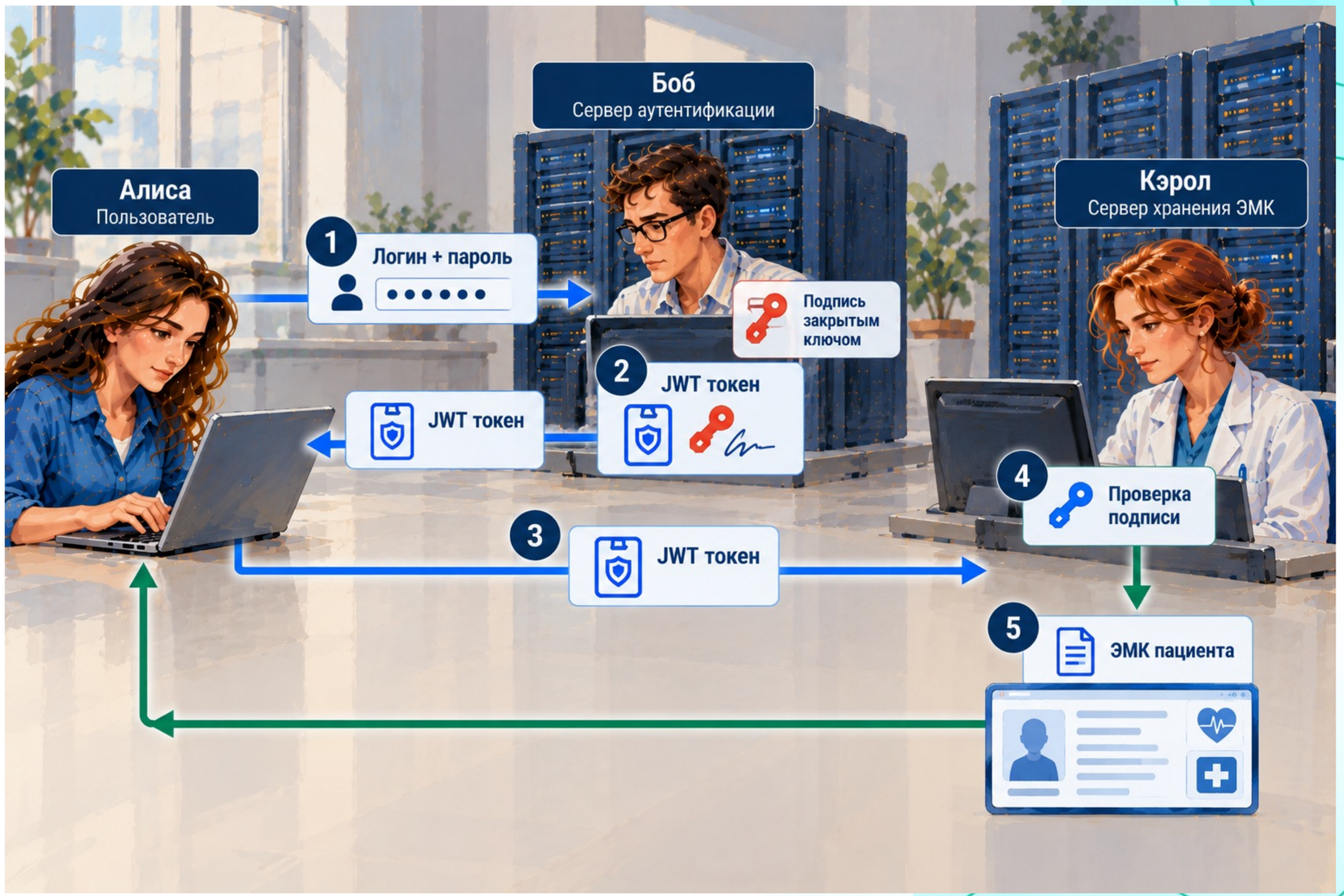
Stateful vs Stateless

- Распределенная система или нет?
- Плюсы Stateful: мгновенный отзыв, контроль над сессиями, нет проблемы размера метаданных
- Минусы Stateful: проблема масштабирования, задержки на запрос к БД
- Плюсы Stateless: дешево масштабировать, разделение ответственности, не ходим к БД при каждом запросе
- Минусы Stateless: сложно мгновенно отозвать, сложно ротировать ключи

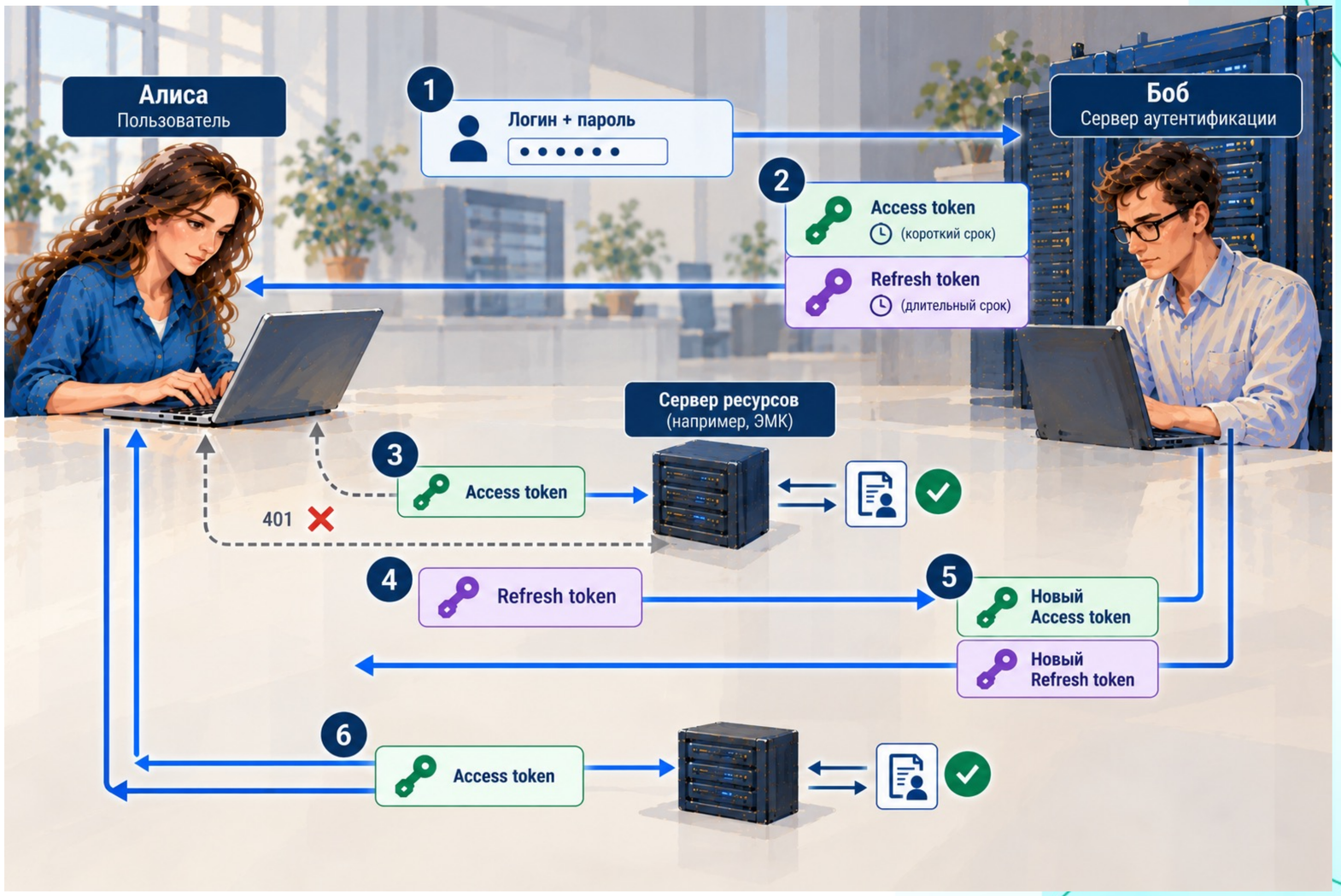
Токены: JWT


Алиса
Пользователь
1
Логин и пароль
2
JWT токен
Боб
Сервер аутентификации
JWT
eyJhbGciOi
JSUzI1NiIs
InR5cCI6Ik
pXVCJ9
.
eyJzdWIiOi
JhbGljZSIs
InJvbGUiOi
JtZWRpYyIs
ImV4cCI6MT
c2MDEwMjQw
MCwic2NvcG
UiOiJlbXI6
cmVhZCJ9
.
MEQCIF7aQ
9r5H7Vf9KQ
3Zr8vJ1tX
eZr0x4Qm3
cZp9l8wJ8
2QIDAQAB
Header
{
"alg": "RS256",
"typ": "JWT"
}
Payload (Claims)
{
"sub": "alice",
"role": "medic",
"exp": 1760102400,
"scope": "emr:read"
}
Signature
RS256(
base64UrlEncode(header) + "." +
base64UrlEncode(payload),
private_key_Bob
)

Токены: JWT


Боб
Сервер аутентификации
Алиса
Пользователь
Кэрол
Сервер хранения ЭМК
1
Логин + пароль
Подпись закрытым ключом
2
JWT токен
JWT токен
3
JWT токен
4
Проверка подписи
5
ЭМК пациента

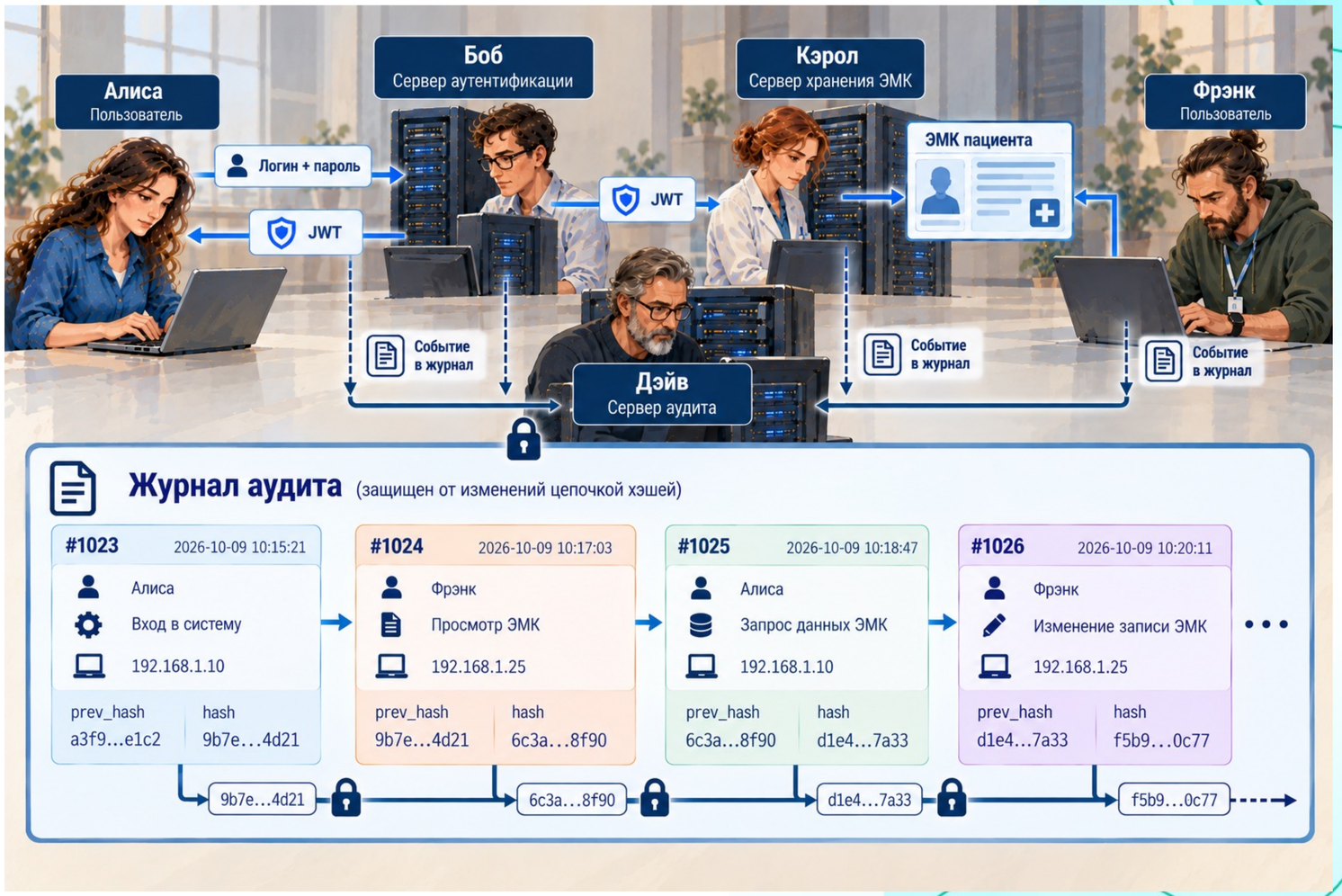
Токены: JWT


Алиса
Пользователь
1
Логин + пароль
Боб
Сервер аутентификации
2
Access token
(короткий срок)
Refresh token
(длительный срок)
Сервер ресурсов
(например, ЭМК)
3
Access token
401
4
Refresh token
5
Новый
Access token
Новый
Refresh token
6
Access token

Токены: Уязвимости

- CSRF
- XSS
- …

Аудит


Алиса
Пользователь
Боб
Сервер аутентификации
Кэрол
Сервер хранения ЭМК
Фрэнк
Пользователь
ЭМК пациента
Логин + пароль
JWT
JWT
Событие в журнал
Событие в журнал
Событие в журнал
Дэйв
Сервер аудита
Журнал аудита (защищен от изменений цепочкой хэшей)
#1023 2026-10-09 10:15:21
Алиса
Вход в систему
192.168.1.10
prev_hash a3f9...e1c2
hash 9b7e...4d21
#1024 2026-10-09 10:17:03
Фрэнк
Просмотр ЭМК
192.168.1.25
prev_hash 9b7e...4d21
hash 6c3a...8f90
#1025 2026-10-09 10:18:47
Алиса
Запрос данных ЭМК
192.168.1.10
prev_hash 6c3a...8f90
hash d1e4...7a33
#1026 2026-10-09 10:20:11
Фрэнк
Изменение записи ЭМК
192.168.1.25
prev_hash d1e4...7a33
hash f5b9...0c77
9b7e...4d21
6c3a...8f90
d1e4...7a33
f5b9...0c77